

Wildcard postMessage / Missing Origin Validation

Assessment Identifier: **WS-STA-01** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: HIGH	CVSS: 7.4	CWE: CWE-346
OWASP: A05 / A07	WASC ID: N/A	Confidence: High candidate
Target / Component: src/components/LiveWebcamsPanel.ts	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/src/components/LiveWebcamsPanel.ts	Parameter: targetOrigin: '*'

1. Description

The application uses window.postMessage() with the target origin set to '*'. Data including storedHtml is sent without restricting delivery to a specific trusted origin. This may permit cross-origin message abuse if the receiving context is not strictly controlled.

2. Steps to Reproduce

- Run the application in an authorized local testing environment.
- Navigate to Live Webcams.
- Inspect iframe communication.
- Confirm the postMessage target origin is '*'.
- Determine whether an unintended origin can receive the message.

3. Controlled Proof of Concept

Safe Proof of Concept:
 Instrument the receiving iframe with a message listener and log event.origin and event.data.
 // Code demonstration:
 window.postMessage({ type: 'WEBCAM_FRAME', data: storedHtml }, '*');
 // The test only demonstrates message delivery and does not extract or transmit sensitive data.

4. Business & Security Impact

If the receiving context can be controlled or trusted incorrectly, information may be delivered to an unintended origin. Impact depends on the data transmitted and surrounding application logic.

5. Remediation Recommendations

Primary Fix: Replace '*' with an explicit trusted origin allowlist. Validate event.origin on the receiving side and avoid sending sensitive data to untrusted contexts.

- Replace '*' with an explicit trusted origin allowlist (e.g., 'https://app.worldmonitor.com').
- Validate event.origin strictly on the receiving window message listener before processing payload data.
- Avoid transmitting sensitive authentication state or rendered HTML markup over postMessage channels.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
 This finding was identified through static analysis of repository source code and configuration files. Per

assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*